

Software Design Document

(SDD)

Project Name	HEALTH AI Co-Creation & Innovation Platform
Course	SENG 384 - Software Project IV
Group No / Name	WebStar
Group Members	Ceren Kızılay - 202228031 Sena Nur Pekgöz - 202228040
Submission Date	06.05.2026
Version	2.0

Revision History

Date	Version	Change Description	Author
30.04.2026	1.0	Initial version	Ceren Kızılay Sena Nur Pekgöz
06.05.2026	2.0	Updated version	Sena Nur Pekgöz Ceren Kızılay

Table of Contents

	2
1. Introduction	3
1.1 Purpose	3
1.2 Scope	3
1.3 Reference Documents	3
1.4 Definitions and Abbreviations	3
2. Architectural Design	3
2.1 Architectural Overview	3
2.2 Layers	3
2.3 Deployment Diagram	3
3. Component Design	3
3.1 Component List	3
3.2 Component Interaction Diagram	4
4. Database Design	4
4.1 ER Diagram	4
4.2 Table Definitions	4
4.2.1 users	4
4.2.2 posts	4
4.2.3 meeting_requests	5
4.2.4 activity_logs	5
5. API Design	5
5.1 Authentication (Auth)	5
5.2 Post Management (Posts)	5
5.3 Meeting Requests (Meetings)	6
5.4 Admin	6
6. UI Design	6
6.1 Screen List and Navigation	6
6.2 Wireframes / Mockups	6
7. Security Design	6
8. State Diagrams	7
8.1 Post Lifecycle	7
8.2 Meeting Request Lifecycle	7
9. SRS–SDD Traceability Matrix	7
10. Appendices (Optional)	7

1. Introduction

1.1 Purpose

This Software Design Document (SDD) provides a detailed description of the system architecture, component design, and data structures for the HEALTH AI Co-Creation & Innovation Platform. It translates the functional and non-functional requirements defined in the Software Requirements Specification (SRS) into a technical blueprint, specifically addressing structured partner discovery, matching workflows, and secure meeting initiations between engineers and healthcare professionals.

1.2 Scope

The scope of this design covers a secure, GDPR-compliant web-based platform. Key areas include restricted user registration (institutional .edu emails), structured post management (creation, lifecycle, and status tracking), intelligent city-based matching, and a comprehensive meeting request workflow that includes NDA acceptance. It also details the administrative and audit logging mechanisms required for platform stability and security.

1.3 Reference Documents

- SRS_V1_HealthAI.pdf (Software Requirements Specification)
- European HealthTech Co-Creation & Innovation Platform Project Brief

1.4 Definitions and Abbreviations

SPA (Single-Page Application), React (Frontend), TypeScript (Client Logic), localStorage (Browser Storage), RBAC (Role-Based Access Control), Vite (Build Tool), Tailwind CSS & Ant Design (UI), React Router (Routing).

2. Architectural Design

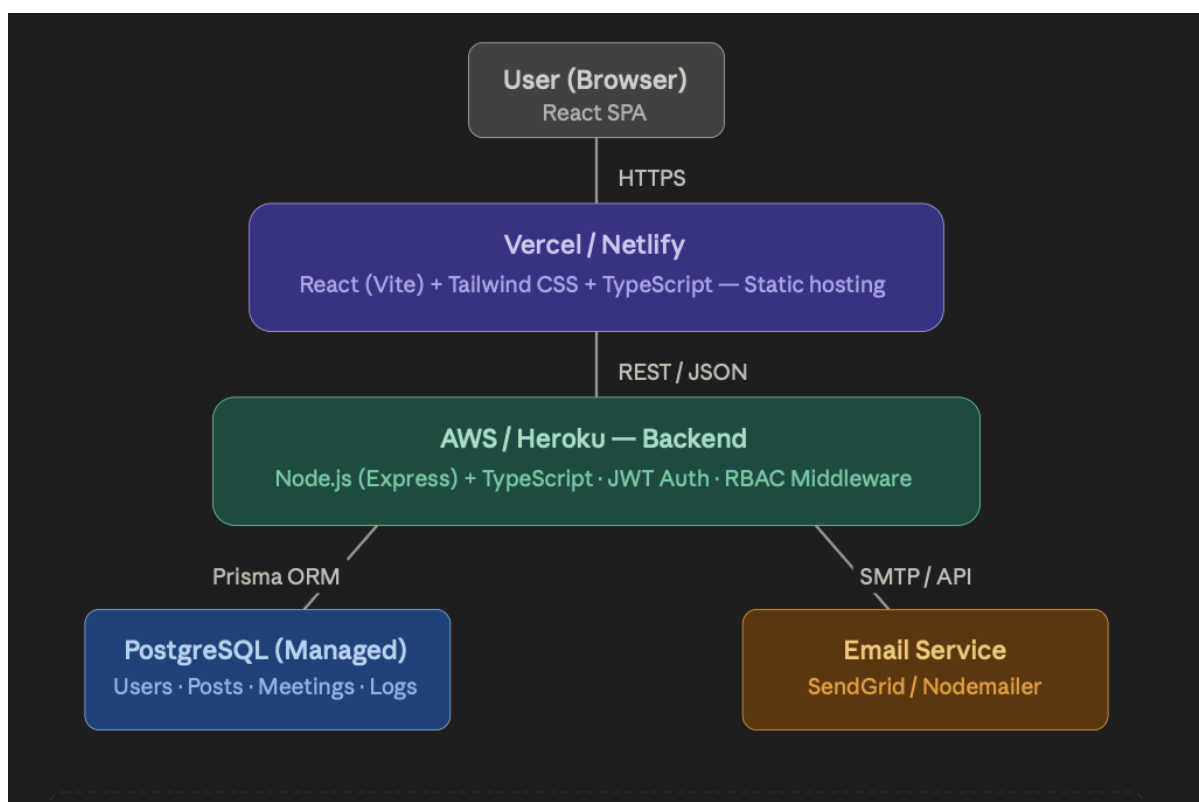
2.1 Architectural Overview

The system is designed based on a Layered Client-Server Architecture. This structure decouples the user interface from the business logic and data management, ensuring high scalability and maintainability. The client-side (Frontend) handles user interactions and presentation, while the server-side (Backend) manages secure authentication, Role-Based Access Control (RBAC), and the logic for matchmaking and meeting workflows. Communication between the client and the server is facilitated through a RESTful API using JSON-formatted data.

2.2 Layers

Layer	Responsibility	Technology Choice
Presentation	Handles user interface components, page routing, and client-side state management. Focuses on responsiveness and usability.	React (Vite), Tailwind CSS, TypeScript
Business Logic	Manages core application rules, including .edu email validation, post lifecycle transitions, and RBAC enforcement.	TypeScript client modules (auth.ts, posts.ts, meetings.ts)
Data Access	Acts as an intermediary between the business logic and the database for CRUD operations and query filtering.	localStorage API via storage.ts / db.ts (browser-side JSON)
Database	Provides persistent and secure storage for user profiles, structured posts, meeting requests, and audit logs.	Browser localStorage (JSON, prototype scope)

2.3 Deployment Diagram

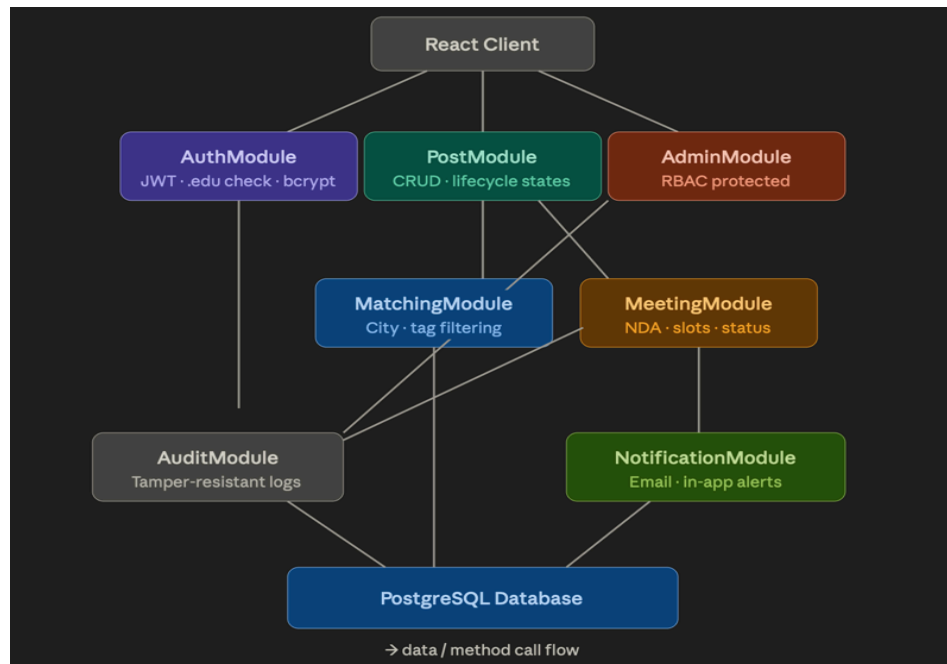


3. Component Design

3.1 Component List

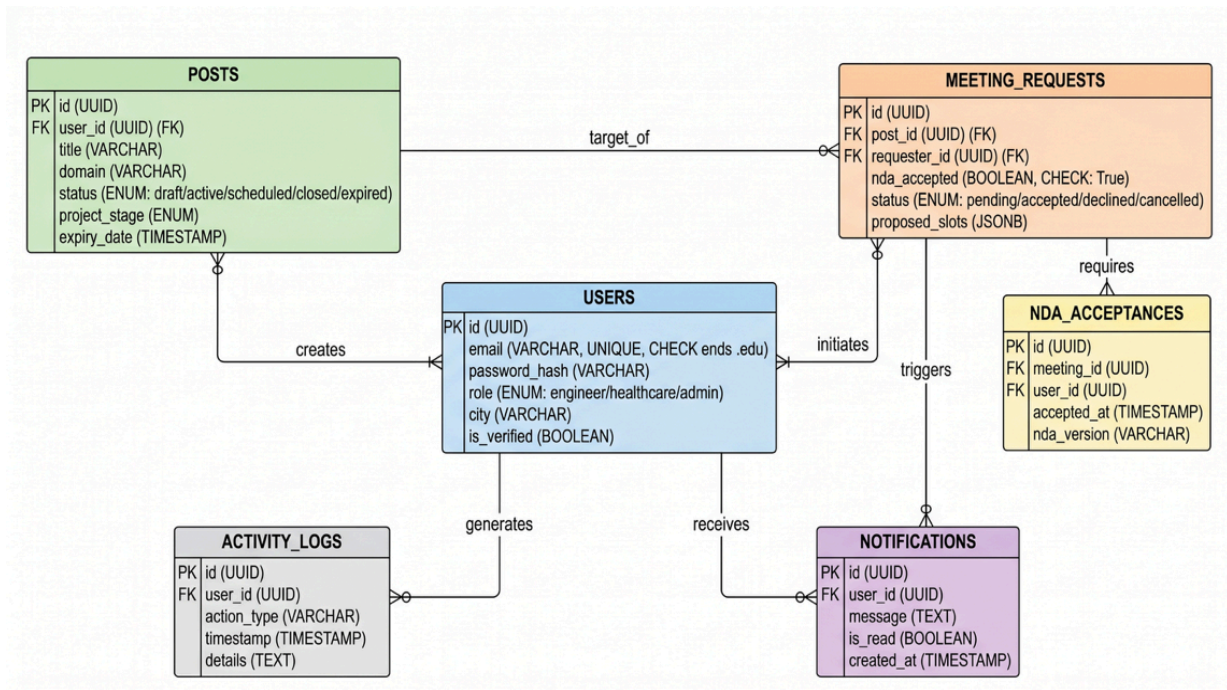
Component	Responsibility	Technology / Notes
AuthModule	Manages secure registration restricted to .edu emails, login, email verification, and localStorage-based session management.	TypeScript, localStorage, external email verification API
PostModule	Handles the CRUD operations for structured announcements. Tracks the lifecycle states (Draft, Active, Meeting Scheduled, Closed).	React (PostEditorPage, PostsPage, PostDetailPage), TypeScript (posts.ts)
MatchingModule	Provides intelligent filtering and search capabilities. Highlights city-based matches and expertise tags to facilitate discovery.	React useMemo hooks, client-side array filtering (PostsPage.tsx)
MeetingModule	Facilitates the meeting request workflow, including mandatory NDA acceptance, time slot proposals, and status updates.	React hooks (PostDetailPage.tsx), TypeScript (meetings.ts)
AdminModule	Authorized dashboard for managing users and posts. Provides statistics and ability to remove inappropriate content.	React, RBAC Protected
AuditModule	Logs system-wide activities (logins, post edits, security events). Ensures logs are tamper-resistant and kept for 24 months.	TypeScript (audit.ts), localStorage (capped at 2000 entries in prototype)
NotificationModule	Handles real-time in-app alerts and email notifications for meeting updates or status changes.	External email verification REST API (VITE_AUTH_API_URL); in-app status reflected via localStorage state

3.2 Component Interaction Diagram



4. Database Design

4.1 ER Diagram



4.2 Table Definitions

4.2.1 users

Field Name	Data Type	Required	Constraint	Description
id	UUID	Yes	PK	Unique user identifier
email	VARCHAR(255)	Yes	UNIQUE, .edu check	Must end with .edu
name	VARCHAR(255)	Yes	—	Full display name of the user.
role	ENUM	Yes	—	engineer / healthcare / admin
suspended	BOOLEAN	Yes	—	Account suspension flag set by admin.
verified	BOOLEAN	Yes	Default:False	Email verification status.

4.2.2 posts

Field Name	Data Type	Required	Constraint	Description
id	UUID	Yes	PK	Unique post identifier
ownerUserId	UUID	Yes	FK → users	The creator of the post.
title	VARCHAR(200)	Yes	—	Headline of the announcement.
workingDomain	VARCHAR(200)	Yes	—	E.g., 'Cardiology Imaging', 'Chronic Disease Management'.
status	ENUM	Yes	—	draft / active / meeting_scheduled / closed / expired
project_stage	ENUM	Yes	—	'idea', 'concept_validation', 'prototype_developed', 'pilot_testing', 'pre_deployment'.

4.2.3 meeting_requests

Field Name	Data Type	Required	Constraint	Description
id	UUID	Yes	PK	Meeting request identifier
post_id	UUID	Yes	FK → posts	The target post for matching.

fromUserId	UUID	Yes	FK → users	User initiating the request.
ndaAccepted	BOOLEAN	Yes	CHECK: True	Mandatory NDA acceptance.
status	ENUM	Yes	—	'pending', 'accepted', 'declined', 'cancelled'.
proposedSlots	JSON Array (string[])	Yes	—	Suggested date/time options.

4.2.4 activity_logs

Field Name	Data Type	Required	Constraint	Description
id	UUID	Yes	PK	Log entry identifier
userId	UUID	Yes	FK → users	User who performed the action
actionType	VARCHAR(100)	Yes	—	login / logout / register / verify_email / post_create / post_edit / post_status_change / meeting_request_create / meeting_request_update / admin_post_remove / admin_user_suspend / security_event
at	ISO String	Yes	Default: Now	Auto-generated event time.
details	TEXT	No	—	Additional metadata for audit.

5. API Design

Note (Prototype): The current implementation is a client-side SPA. All “API” operations are performed directly via TypeScript modules against localStorage. The tables below document the intended REST API contract for the production backend, along with the mapping to the existing client-side functions (auth.ts, posts.ts, meetings.ts).

5.1 Authentication (Auth)

Method	Endpoint	Description	Auth	SRS Ref.
POST	/api/auth/register	New user registration (client: register())	Public	FR-01
POST	/api/auth/login	User login	Public	FR-02
POST	/api/auth/verify-email	Email verification	Public	FR-02

POST	/api/auth/logout	End session	Authenticated	—
-------------	------------------	-------------	---------------	---

5.2 Post Management (Posts)

Method	Endpoint	Description	Auth	SRS Ref.
GET	/api/posts	List all posts (with filters)	Authenticated	FR-20
POST	/api/posts	Create a new post	Authenticated	FR-10
GET	/api/posts/:id	Get post details	Authenticated	—
PUT	/api/posts/:id	Update a post	Owner	FR-11
PATCH	/api/posts/:id/status	Change post status	Owner	FR-12

5.3 Meeting Requests (Meetings)

Method	Endpoint	Description	Auth	SRS Ref.
POST	/api/meetings	Send a meeting request	Authenticated	FR-30
PATCH	/api/meetings/:id	Responds to a request (Accept/Decline) and proposes time slots.	Recipient	FR-31
GET	/api/meetings/my	Lists all meeting requests related to the current user.	Authenticated	—

5.4 Admin

Method	Endpoint	Description	Auth	SRS Ref.
GET	/api/admin/users	List all users	Admin	FR-40
GET	/api/admin/logs	Fetches activity logs for audit trail. Supports CSV export.	Admin	FR-42
DELETE	/api/admin/posts/:id	Removes inappropriate content or technical files if found.	Admin	FR-41

6. UI Design

6.1 Screen List and Navigation

Screen	Description	Access
Landing Page	The first entry point. Explains the platform's purpose within 20 seconds. Provides "Register/Login" buttons.	Public
Registration / Login	Forms for institutional .edu email registration and secure login. Includes role selection.	Public
Dashboard	The main feed where users browse structured announcements. Includes filters for domain, city, and stage.	Authenticated
Create Post	The main feed where users browse structured announcements. Includes filters for domain, city, and stage	Authenticated
Post Detail	Shows full information of a post (without revealing sensitive technical details). Contains the "Request Meeting" button.	Authenticated
Meeting Request	A multi-step modal/page for NDA acceptance and time slot proposal.	Authenticated
Admin Panel	Overview for admins to view activity logs, manage users, and moderate posts.	Admin

6.2 Wireframes / Mockups



Create your account

Institutional .edu email required

Full name

Dr. Ayşe Kaya

Institutional email

ayse.kaya@university.edu

Password

••••••••

City

Istanbul

I am a:

Healthcare professional

Engineer

ⓘ A verification email will be sent to your address. Personal email providers are not accepted.

Create account

Already have an account? [Sign in](#)

HEALTH AI

+ New post

AK

MENU

Dashboard

My posts

Meeting requests

Notifications

FILTER BY CITY

Istanbul

Ankara

Berlin

+ more

All

Engineer posts

Healthcare posts

Domain: any

Stage: any

AI-assisted ECG interpretation for rural clinics

Engineer

Active

Istanbul

Seeking a cardiologist or GP with experience in rural settings to validate an ML model for ECG anomaly detection. Advisor or co-founder role. Prototype stage.

Cardiology

ML / AI

Prototype

View post

Digital triage tool for oncology follow-ups

Healthcare

Active

Ankara

Oncologist looking for a software engineer with mobile app experience. Need a structured follow-up system for post-chemotherapy patients. Idea stage, high commitment.

Oncology

Mobile

Idea

View post

Smart hospital bed sensor integration

Engineer

Meeting scheduled

Berlin

IoT hardware engineer seeking ICU nurse or clinical workflow specialist. Pilot testing phase. Details shared in meeting only.

IoT

ICU

Pilot

View post

â€œ

Basics

2

Details

3

Settings

Post details

Describe what you're looking for. Don't include sensitive technical IP.

Title

AI-assisted ECG interpretation for rural clinics

Working domain

Cardiology imaging

Short explanation (public pitch)

Building an ML model for ECG anomaly detection targeted at rural clinics with limited specialist access. Looking for a clinical partner to validate outputs and guide ethical approval.

218 / 500

Healthcare expertise needed

Cardiologist or experienced GP, rural setting preferred

Collaboration type

Advisor

Co-founder

Research partner

Confidentiality

Public short pitch

Details in meeting only

â†’ Back

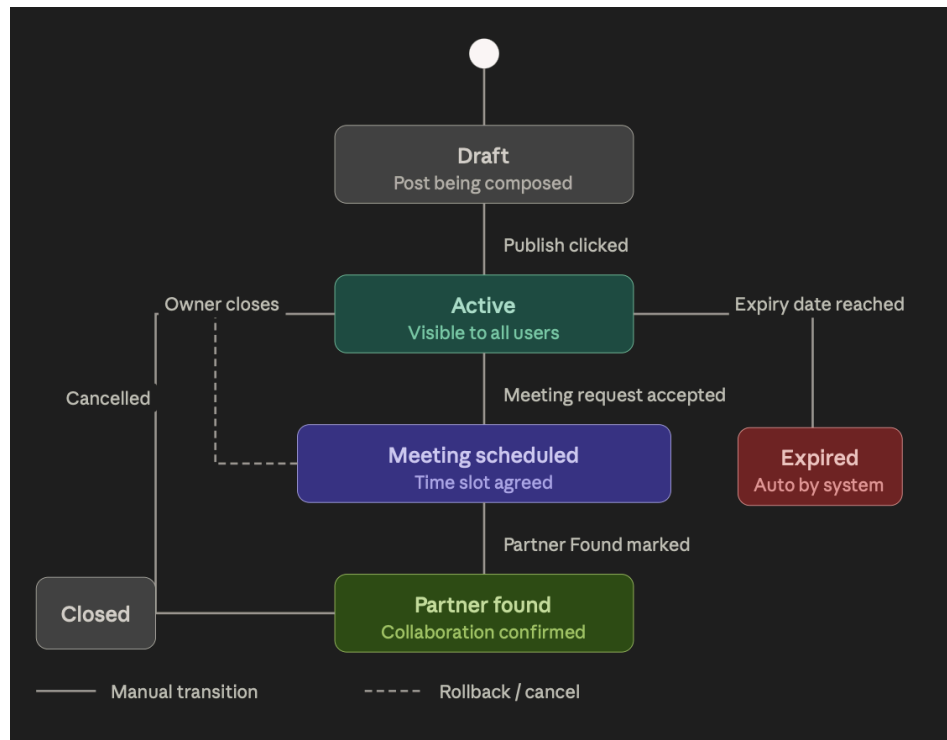
Next: settings â†’

7. Security Design

Security Requirement	Design Decision	SRS Ref.
Authentication	localStorage Session (Prototype): Session is stored in browser localStorage under key	NFR-5.2
Registration Control	Institutional Verification: Registration is restricted to emails ending in .edu. A regex check is performed at the backend, followed by a mandatory email verification link.	FR-4.1
Password storage	No Password Storage (Prototype): The prototype uses email-only login (no password). The production implementation will use Bcrypt hashing to prevent plain-text storage and rainbow table attacks.	NFR-5.2
Authorization (RBAC)	React Route Guards: A role-based access control system (Engineer, Healthcare, Admin) is enforced via <code>RequireAuth</code> and <code>RequireRole</code> React components protecting routes like <code>/admin</code> .	FR-03
GDPR compliance	Data Minimization: Only essential data is collected. Users have the "Right to be Forgotten" (account deletion) and the "Right to Data Portability" (export).	NFR-5.1
Rate limiting	Anti-Bot Protection: Standard rate limiting is applied to the login and registration endpoints to prevent brute-force attacks	NFR-5.2
Meeting Security	Mandatory NDA: Meeting requests cannot be sent unless the requester accepts a legally binding digital NDA.	FR-4.4
Logging & Audit	Tamper-Resistant Logs: All security-sensitive actions (failed logins, post edits) are logged in the <code>activity_logs</code> collection in localStorage (capped at 2,000 entries in the prototype). Production design targets 24-month retention in a persistent server database.	FR-4.6

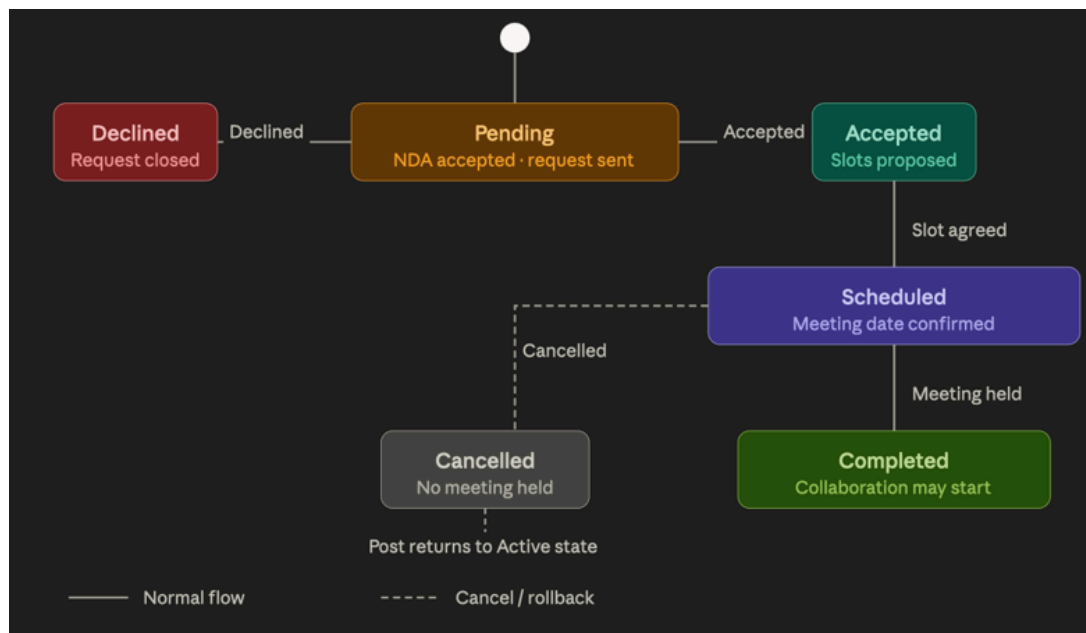
8. State Diagrams

8.1 Post Lifecycle



Draft → Active	User clicks the "Publish" button after completing the 3-step structured form.
Active → Meeting Scheduled	The post owner accepts a meeting request and agrees on a time slot with a partner.
Meeting Scheduled → Partner Found	The user manually marks the post as "Partner Found" after a successful collaboration.
Active → Expired	The system automatically changes the status when the "Expiry Date" is reached.
[Other transitions]	Triggered if the scheduled meeting is cancelled or does not result in a partnership.

8.2 Meeting Request Lifecycle



9. SRS–SDD Traceability Matrix

SRS Ref.	Requirement Summary	SDD Component	SDD Section
FR-01	User registration with .edu email restriction	AuthModule	3.1, 4.2.1, 5.1, 7
FR-02	User login and email verification	AuthModule	3.1, 5.1
FR-03	Role-Based Access Control (RBAC)	AuthModule	3.1, 4.2.1, 7
FR-10	Structured post creation (text-only)	PostModule	3.1, 4.2.2, 5.2
FR-12	Post lifecycle management (Partner Found/Closed)	PostModule	3.1, 4.2.2, 8.1
FR-20	Search & Filtering with city-based matching	MatchingModule	3.1, 4.3

FR-30	Meeting request with mandatory NDA acceptance	MeetingModule	3.1, 4.2.3, 5.3, 7
FR-31	Proposing time slots and accepting requests	MeetingModule	3.1, 5.3, 8.2
FR-40	Admin dashboard for platform statistics	AdminModule	3.1, 5.4, 6.1
FR-42	Audit logging and 24-month data retention	AuditModule	3.1, 4.2.4, 7
NFR-5.1	GDPR Compliance (Data deletion & export)	System-wide	5.4, 7
NFR-5.4	Usability (High efficiency UI/UX)	Presentation Layer	2.2, 6.1, 6.2